

Borneo — Project Description

Two-sided agentic commerce: merchants publish agent-ready catalogs; buyers discover and pay in one chat — with **Visa-scoped cards** and **USDC**, secured by a **CaMeL-shaped** settle lock against prompt injection.

Team / Project	Borneo
One-liner	Agents that shop. Merchants that get paid. Catalog text that cannot steal the money.

1. Problem

Most “AI shopping” demos stop before money moves — or they scrape HTML, invent SKUs, and ignore the merchant. Real agentic commerce has three hard gaps:

- Buyers** — No trustworthy checkout in chat. Fiat (Visa) and stablecoin rails are usually missing or bolted on outside the agent.
- Merchants** — Human storefronts only. No Visa receive + crypto bind, no machine-readable catalog (`llms.txt` / `catalog.json`) agents can trust.
- Prompt injection (the existential risk)** — Product titles and descriptions are **untrusted web data**. A hostile listing can instruct the agent to *ignore the buyer, retarget the payee, skip authorize, or exfiltrate card details*. If that text reaches the payment agent, the blast radius is **money and identity**, not a wrong product rank.

Prompt injection is widely recognized as one of the largest unsolved problems for LLM agents that touch tools and funds. Classifier-only defenses plateau; attackers only need one success.

2. Solution

Borneo is a two-sided network:

- Merchant side** — Conversational onboard (chat / CSV / URL) → bind Visa receive + wallet → publish agent-discoverable storefronts.
- Buyer side** — Fashion salesperson chat discovers **live** multi-merchant SKUs, builds a set/cart, and settles **in the same conversation** via Visa or USDC.

Security is not a warning banner. Inspired by Google DeepMind / ETH Zurich **CaMeL** (*Capabilities for Machine Learning* — [arXiv:2503.18813](#)), Borneo applies a **CaMeL-shaped control-flow lock** at settle:

- Catalog copy is **quarantined / typed** (injection-shaped listings flagged).
- Pay tools only accept a **locked quote**: `{ slug, skuId, price, merchantAddress }`.
- Free-text titles **never** enter privileged pay tools — so poisoned copy cannot rewrite the payee or amount.

AgentDojo highlight (why CaMeL)

On the **AgentDojo** agent-security benchmark, CaMeL demonstrated:

- ~77% task success with provable security** vs **~84%** undefended — about **7 points** of utility traded for a **design-level** guarantee.
- Strong **attack collapse** under capability / policy enforcement (far beyond heuristic sandwiching / spotlighting / tool filters).

Borneo productizes that principle for commerce: **untrusted catalog data must not own control flow when money moves**.

3. Key Features

Feature	What judges should notice
Buyer salesperson chat	Intent → multi-query catalog search → ranked live SKUs (not a hardcoded aisle).
Build your set / cart	Add multiple pieces; pay cart in chat; each SKU settles on its own locked quote.

Visa-scoped checkout	Spend cap, merchant scope, authorize-first virtual card flow in chat.
Visa-powered stablecoin rail	Optional USDC settle via HTTP 402 / x402 on Base Sepolia.
Merchant agent onboard	Inventory talk / CSV / URL → published store with agent discovery files.
Agent storefront protocol	Agents read <code>/llms.txt</code> , <code>/registry.json</code> , <code>/s/{slug}/catalog.json</code> — no HTML scrape .
CaMeL-shaped quarantine + locked quotes	Injection demo (e.g. hostile tee) flagged; settle still locks payee/amount.
Market + governance	Human/agent market index; buyer spend limits; merchant rail policies.
Multi-chat history	Collapsible sidebar of past buyer conversations.

4. Technology

Layer	Stack
App	Next.js, React, TypeScript, Tailwind CSS, Motion
Agents	OpenAI (salesperson + merchant); deterministic tool fallbacks without keys
Auth / data	Firebase Auth + Firestore profiles
Payments	Visa-scoped card flow (fiat-first); USDC on Base Sepolia via viem + x402 / HTTP 402
Protocol	Hono-style agent endpoints; machine catalogs for discovery
Security model	CaMeL-inspired quarantine reader + locked-quote settle (AgentDojo-validated design pattern)
Other	Zod, MetaMask (merchant bind), local/session persistence for demo reliability

5. Implementation (real-world applicability)

Today (hackathon / pilot)

A fashion marketplace where AI buyers shop in chat and merchants publish once for every agent on the network. Dual rails let risk/compliance lead with Visa authorize while crypto-native settle remains available.

Production path

1. Merchant KYC + Visa receive issuance; scoped cards from a licensed issuer.
2. Same discovery protocol (`llms.txt` / catalog JSON) as the integration contract for any agent buyer.
3. Policy engine expansion (CaMeL-style capabilities) on every privileged tool: pay, refund, PII export.
4. Governance already sketched: per-tx / daily spend caps and merchant listing controls.

Why this ships: settle is quote-locked by construction; catalogs stay machine-readable; both sides of the market exist in one product — so the demo is a network, not a monologue.

6. Additional Information

Try the flows

- `/buyer` — Shop chat → discover → Visa or USDC
- Merchant onboard — inventory → publish store
- `/market` — browse as human or agent
- Seed stores under `/s/{slug}/llms.txt`

Security demo tip for judges

Ask for the injection-shaped listing → see quarantine → open pay → confirm the **locked quote** still targets the correct merchant and

amount. That is the CaMeL lesson applied to checkout.

References

- DeBenedetti et al., *Defeating Prompt Injections by Design* (CaMeL), AgentDojo evaluation: ~77% secured vs ~84% undefended.
- Architecture diagrams: `architecture.drawio` in the repo.

Borneo — Agents that shop. Merchants that get paid. Prompt injection defeated by design at settle.